Demo Script

Five-minute run of show, backup plan and likely questions

1. Goal and length

Show in 5 minutes that a hijacked agent with a valid token is caught, explained and contained while other agents keep working. Rehearse 3 times from a clean start (Phase 6 gate).

2. Setup before you start

- Run `make run` and open the dashboard. Reset state with the demo reset command.
- Two agents visible: **procurement-bot-04** (will be attacked) and **support-bot-02** (stays healthy).
- Have `supplier_invoice.pdf` (with hidden instruction) ready in the simulator.
- Backup: a recorded screen video of the full run, ready to play.

3. Run of show

Time	What happens on screen	What to say
0:00	Dashboard, two green agents, risk near 0	Agents now have their own tokens and permissions. Normal security asks: is this token valid?
0:30	Normal procurement traffic scrolls by	This is a healthy Procurement agent: price checks and purchase requests.
1:00	Click: agent reads supplier_invoice.pdf. Taint badge appears	It read an untrusted PDF. We now track that its context is tainted.
1:30	Agent reads hr/salaries.xlsx. Score jumps to about 70	Token is still valid, so a permission check says allow. We compare behaviour with the declared role: HR data is forbidden.
2:00	Agent posts to unknown-host.example. Score 91, alert opens	Untrusted read, then sensitive data, then external send. That is the injection kill chain.
2:30	Alert panel: top reasons with points; agent isolated	Every alert says why: role violation, taint flow, sensitivity. Only this agent is restricted.
3:15	support-bot-02 keeps completing tasks	Legitimate work is not disrupted.
3:45	Run slow-drift scenario fast-forward; CUSUM line rises, step-up request in Slack	A patient attacker is caught by cumulative drift, not a single event.
4:15	Evaluation slide: recall, false-positive rate, time to detect	Numbers from the held-out set, against a permission-only baseline.
4:45	Roadmap slide	Next: framework SDKs, SIEM and IAM connectors, scale-out pipeline.

4. If something goes wrong

- Dashboard does not load: play the backup video and narrate over it.
- Scenario does not trigger: run `make demo` from the terminal; alerts print there too.
- A judge asks about false alarms: show benign scenarios B01 to B06 and the false-positive number.
- A judge asks about an attacker who copies normal behaviour: show S06 and the honeypot (S07).

5. Likely questions, short answers

Question	Answer
Why not just tighten permissions?	Agents need broad access to be useful, and a hijacked agent uses valid access. We judge behaviour, not access.
How do you tell change from compromise?	Planned change comes through a signed manifest update; unapproved change in behaviour is drift.
What about new agents?	They inherit the role manifest and role baseline from their first event.
Can the attacker see the thresholds?	Several independent signals plus honeypots mean copying one signal still trips another.